Sprint 3 Static Analysis Report

Israel Mora | Ripple / music_discovery | October 20, 2026

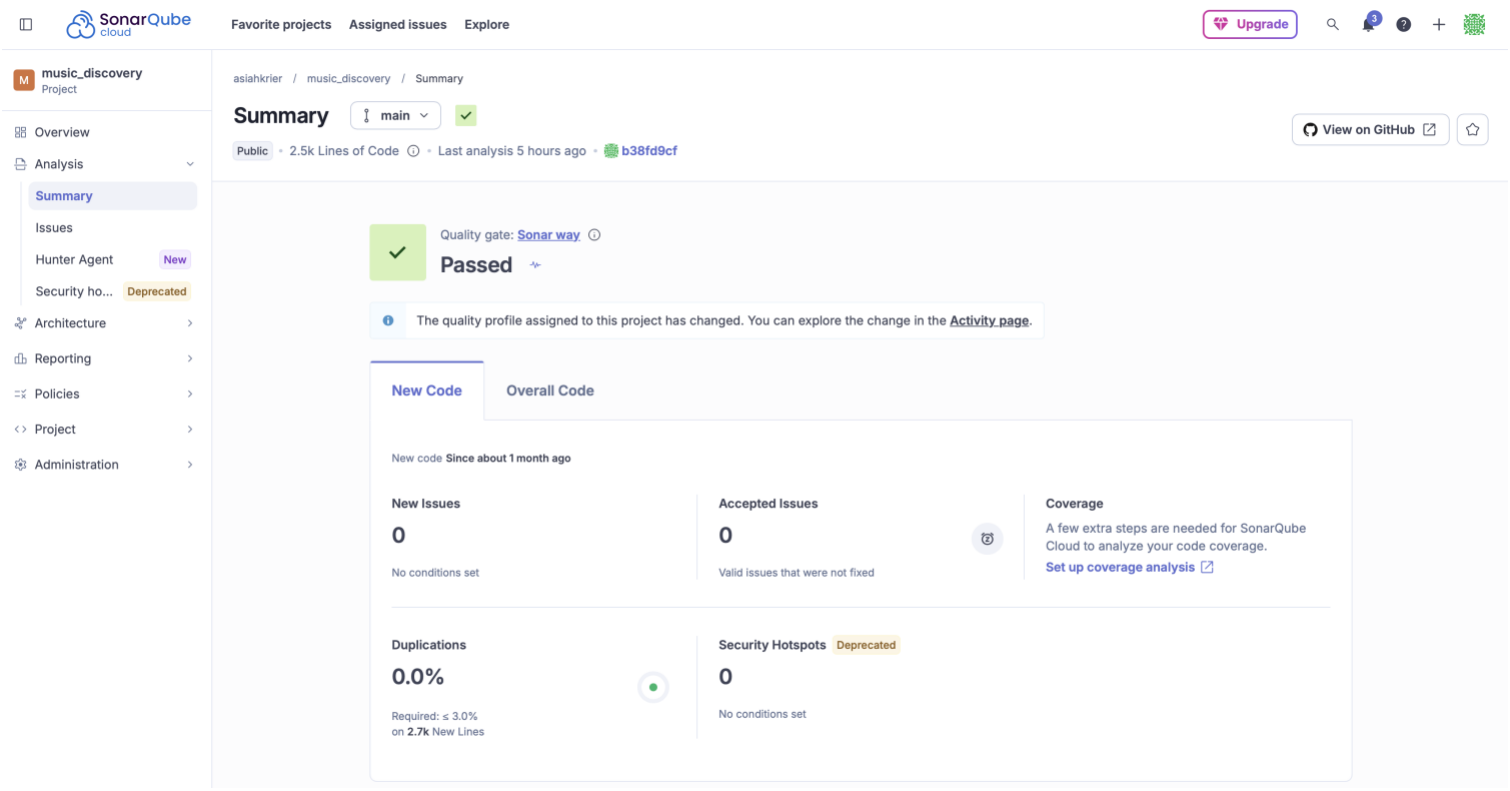
1. Tools Used

• Programming languages: JavaScript and JSX, HTML, CSS; the project also contains SQL migrations.
• SonarQube Cloud: automated source-code quality and security analysis.
• Trivy: filesystem dependency vulnerability scan through GitHub Actions CI.
• Trivy action: v0.36.0, pinned to commit ed142fd0673e97e23eac54620cfb913e5ce36c25. The scanner executable version was not retrieved for this report.

2. Required Metrics

SonarQube - main branch

Latest verified analysis: October 20, 2026 at 2:22 PM CDT. Commit **b38fd9c**. The final main-branch results show a passing Quality Gate and no reported bugs, vulnerabilities, code smells, or security hotspots.



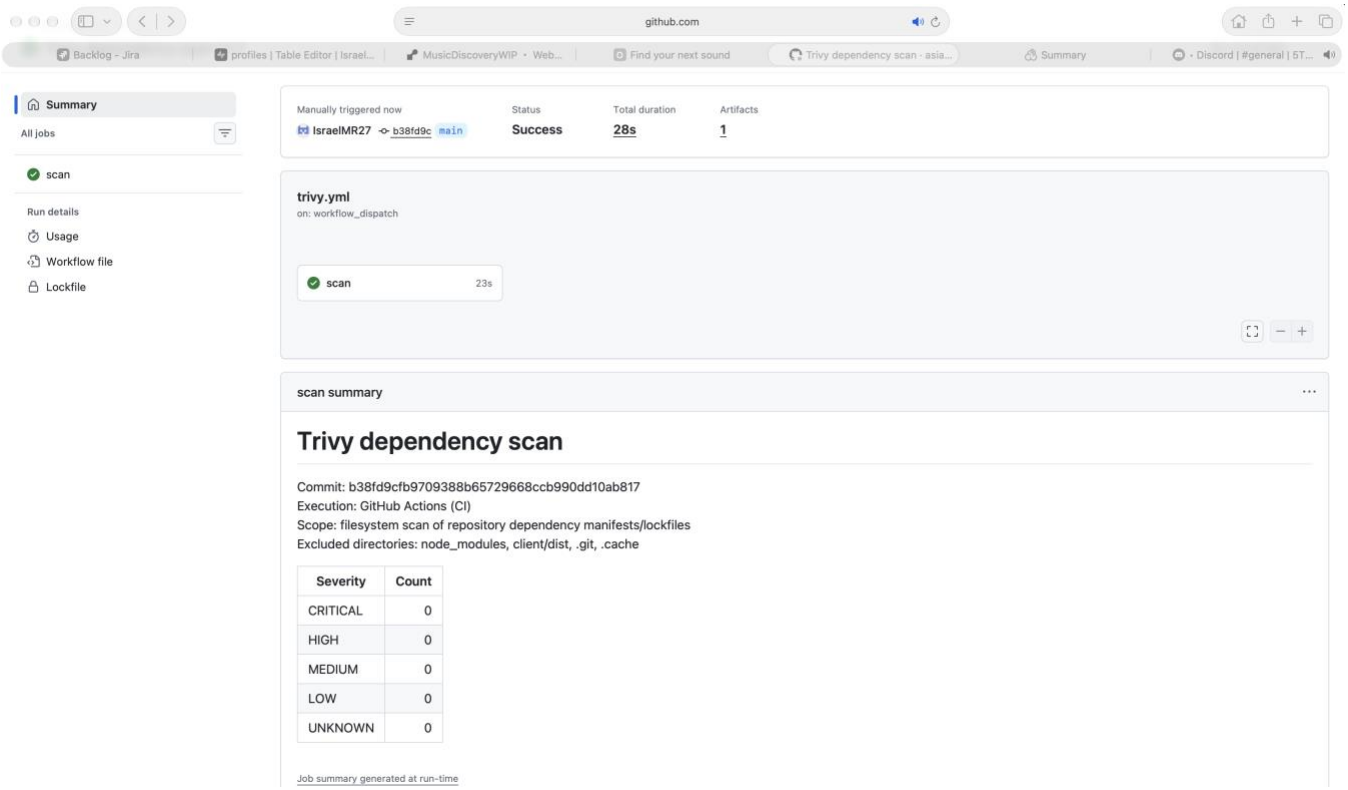
Evidence: SonarQube main-branch dashboard.

2. Required Metrics continued

Trivy - main branch

GitHub Actions run #57 scanned main on October 21, 2026 at approximately 3:17 PM CDT. The run title references the merge of PR #30, but the scanned branch is **main**, not the PR branch.

Scanned commit: b38fd9cfb9709388b65729668ccb990dd10ab817.



The counts above were read from the generated Trivy severity summary. The scan job completed successfully. The workflow uses exit-code: 0, so a green job alone does not prove a clean scan; the zero counts in the summary provide that evidence.

The workflow also displayed a Node.js 20 action-runtime deprecation warning and an Ubuntu runner migration notice. These are CI maintenance notices, not dependency vulnerabilities in the severity table.

Evidence: Main-branch Trivy run and severity summary.

3. Scope

SonarQube: Analyzed the Ripple project in asiahkrier/music_discovery on main. The final analysis reports 2,509 lines of code. Results apply to files included in the configured analysis scope. Custom SonarQube exclusions and per-language coverage were not independently verified for this report.

Trivy: Scanned repository dependency manifests and lockfiles for known vulnerabilities using scan-type: fs and scanners: vuln. All severities were included, and ignore-unfixed was false. Excluded directories: node_modules, client/dist, .git, and .cache. This was not a container-image scan, live Render website scan, or Supabase configuration audit.

4. Trend

Sprint 1 provides the earlier reported baseline. The professor waived the Sprint 2 static analysis report, so no Sprint 2 report baseline is available for comparison. Sprint 2 is marked N/A rather than zero. This does not mean no scanning or fixes occurred during Sprint 2.

Reported metric	Sprint 1 final	Sprint 2	Sprint 3 final
Security vulnerabilities	0	N/A - waived	0
Reliability bugs	0	N/A - waived	0
Maintainability findings	0	N/A - waived	0
Quality Gate	Passed	N/A - waived	Passed
Trivy vulnerabilities	0	N/A - waived	0
Lines of code	308	N/A - waived	2,509

Compared with the Sprint 1 report, the final reported findings remain at zero while analyzed code grew from 308 to 2,509 lines.

During Sprint 3, account features and later updates produced SonarQube findings that were addressed through PR fixes. The final verified main-branch snapshot is clean. Intermediate PR issue counts are not added together because findings can recur across branches and analyses.

5. Reflection

This sprint expanded Ripple with account signup/login, profile customization, saved artists and songs, inline song previews, and artist recommendation updates. Static analysis helped identify unclear conditionals, missing button types, unstable list keys, React context-value changes, accessibility labels, and redundant image alt text. We corrected these issues and updated vulnerable dependencies as part of the quality work.

The passing main-branch Quality Gate and zero Trivy vulnerability counts show the final reported results after the fixes. Next sprint, we will continue reviewing both tools before merging, address the CI runtime warnings, and improve automated test coverage. Static analysis complements functional testing; it does not verify every account, database, or playback behavior.

Fix evidence: PR #27, PR #29, and PR #30. Baseline: Sprint 1 static analysis report.

Required Statement

This static analysis was generated using automated tools during this sprint.